



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-85102 Check Point Quantum Security Gateway VPN RCE Daily Update - 2026-09-23

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-09-23
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-85102 Check Point Quantum Security Gateway VPN RCE Daily Update - 2026-09-23 - CVE / Vulnerability Threat Intelligence Report

Published: 2026-09-23 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
 - 9.1. Detection Logic Summary
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

CVE-2026-85102 Check Point Quantum Security Gateway VPN RCE

Daily Update - 2026-09-23

> Daily automation refresh: This 2026-09-23 report turns current vulnerability intelligence into a finished Lost Boys Cyber report with source-backed analysis, structured tables, detections, and hunt content.

1. Executive Summary

Current-day material update: CVE-2026-85102 is prioritized for the 2026-09-23 UTC production cycle because CISA KEV reporting and supporting vulnerability intelligence indicate defender action is time-sensitive. Improper certificate trust validation during VPN negotiation may permit unauthenticated remote code execution on exposed gateways. Organizations should first confirm exposure, isolate management/VPN surfaces, apply vendor fixes, and hunt for suspicious management-plane access.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2026-85102
Product / Technology	Check Point Quantum Security Gateway / Spark Firewall VPN negotiation certificate-validation flaw
Severity	Critical
Exploitation Status	Listed by CISA KEV / treated as exploited or actively prioritized
Primary Exposure	Check Point VPN gateways, security gateways, and firewall/VPN edge systems exposed to remote-access or site-to-site VPN traffic.
Report Date	2026-09-23

3. Source Review & Confidence

Source	URL	Confidence
CISA KEV alert	https://www.cisa.gov/news-events/alerts/2026/09/22/cisa-adds-four-known-exploited-vulnerabilities-catalog	High
Rapid7 vulnerability database	https://www.rapid7.com/db/vulnerabilities/cve-2026-85102/	Medium
Arctic Wolf advisory	https://arcticwolf.com/resources/blog/cve-2026-85102-cve-2026-85103/	Medium
NHS Digital cyber alert	https://digital.nhs.uk/cyber-alerts/2026/cc-4849	Medium

4. Vulnerability Details

Improper certificate trust validation during VPN negotiation may permit unauthenticated remote code execution on exposed gateways. The highest-risk exposure pattern is an externally reachable edge, VPN, identity, or management plane where exploitation can occur before normal user authentication. Public reporting available to this automation run did not provide a safe packet-level exploit signature; defenders should therefore combine vendor patch validation, surface reduction, and behavior-based monitoring.

5. Attack Scenarios

Scenario	Preconditions	Defender Concern
Internet-edge exploitation	Affected service reachable from attacker-controlled network path	Initial access, device compromise, or credential/session theft
Management-plane follow-on	Attacker reaches admin/API functions after bypass or code execution	Configuration changes, account creation, policy tampering
Pivot from edge appliance	Appliance can reach internal identity, logging, or update systems	Lateral movement and impaired visibility

6. Threat Landscape & Exploitation Status

CISA KEV inclusion elevates this vulnerability above routine patch prioritization. Even when exploit details are incomplete, edge and identity infrastructure vulnerabilities are commonly operationalized quickly because they offer high-value access and may sit outside standard EDR coverage.

7. Affected Products and Exposure

Asset Class	Exposure Check	Priority
Internet-facing management or VPN interfaces	Enumerate externally reachable hosts and compare versions/configuration to vendor guidance	Immediate
Internal management planes	Validate ACLs, admin MFA, and source restrictions	High
Logging/SIEM integrations	Confirm appliance/API audit logs are forwarded and retained	High

8. Mitigation and Workarounds

Priority	Action	Owner
1	Apply vendor fixes or mitigations referenced by the vendor/security advisory.	Network / platform owner
2	Remove public reachability for administrative and API interfaces where operationally possible.	Network security
3	Rotate potentially exposed local/API credentials if compromise cannot be ruled out.	IAM / platform owner
4	Review logs for new admins, policy changes, abnormal API calls, and outbound connections from the appliance.	SOC

9. Detection Engineering

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
--------	------------------	---------------

New administrative session from rare IP/user-agent	Appliance, VPN, WAF, identity logs	Catch post-exploitation management use
Appliance initiating unusual outbound connections	Firewall/netflow/DNS	Identify staging or C2 from an edge device
Configuration or account changes outside maintenance windows	Appliance audit logs	Surface persistence and policy tampering
<pre> title: Edge Appliance Management Abuse After Critical Vulnerability Exposure status: experimental description: Detects suspicious management activity that may follow exploitation of an edge/VPN/identity appliance vulnerability. logsource: product: firewall service: appliance-audit detection: selection_action: EventType contains: - 'admin login' - 'api login' - 'configuration changed' - 'user created' filter_known_sources: SourceIp: - '10.0.0.0/8' - '192.168.0.0/16' condition: selection_action and not filter_known_sources level: high DeviceNetworkEvents where Timestamp > ago(14d) where DeviceName has_any ('vpn','gateway','firewall','ise','checkpoint','cisco') summarize Connections=count(), RemoteIPs=dcount(RemoteIP), RemoteUrls=make_set(RemoteUrl, 20) by DeviceName, InitiatingProcessFileName, RemotePort where Connections > 25 or RemoteIPs > 10 order by Connections desc </pre>		

10. Threat Hunting

Hunt Hypothesis	Query Focus	Expected Action
An exposed appliance was accessed from an unusual network.	Rare source IPs, ASN changes, and first-seen user agents.	Validate source and revoke sessions.
Exploitation produced management-plane changes.	New admin users, API tokens, policy exports/imports.	Roll back unauthorized changes and preserve logs.
Compromised edge device staged tools or reached C2.	DNS/netflow from the appliance to rare destinations.	Isolate device and collect forensic image/config.
<pre> CommonSecurityLog where TimeGenerated > ago(14d) where DeviceVendor has_any ('Check Point','Cisco') or DeviceProduct has_any ('ISE','Security Gateway','VPN') where Activity has_any ('login','api','configuration','administrator','policy','token') summarize Count=count(), Activities=make_set(Activity, 20), Sources=make_set(SourceIP, 50) by DeviceName, DestinationHostName, DeviceVendor, DeviceProduct order by Count desc </pre>		

11. MITRE ATT&CK Mapping

Technique	Name	Rationale
T1190	Exploit Public-Facing Application	Edge or management-plane exploitation path.
T1136	Create Account	Common persistence action after management access.
T1090	Proxy	Compromised edge systems can proxy follow-on access.
T1562	Impair Defenses	Appliance policy/logging changes can reduce visibility.

12. Validation / Lab Testing

No exploit reproduction was attempted in this automated production run. Validation should be limited to asset/version checks, vendor advisory comparison, and controlled log-review/hunt execution.

13. Recommended Actions Summary

Timeframe	Action
Today	Patch/mitigate, restrict exposure, preserve logs, and run hunts above.
48 hours	Validate credentials/tokens, review config integrity, and confirm backups.
7 days	Add continuous monitoring for management-plane anomalies and supplier exposure.

14. References

- [1] CISA KEV alert: <https://www.cisa.gov/news-events/alerts/2026/09/22/cisa-adds-four-known-exploited-vulnerabilities-catalog>
- [2] Rapid7 vulnerability database: <https://www.rapid7.com/db/vulnerabilities/cve-2026-85102/>
- [3] Arctic Wolf advisory: <https://arcticwolf.com/resources/blog/cve-2026-85102-cve-2026-85103/>
- [4] NHS Digital cyber alert: <https://digital.nhs.uk/cyber-alerts/2026/cc-4849>